

# AccsMarkets — Deep Audit

Everything added and fixed, everything still missing, and what needs you

accsmarkets.org · Next.js 14 · Prisma / MySQL · 23 September 2026

This covers the whole codebase — admin panel (46 pages, ~100 admin API routes), user-facing site (127 page routes, 259 API routes), backend libraries, middleware, the 80-model schema, the sweep/cron jobs and the realtime server. Every finding was located in source and verified against the live database or the running site where possible.

6

releases shipped to production, all verified live

3

critical login holes closed (incl. full account forgery)

2

money bugs that lost real revenue, now fixed

0

type errors, dead links, or unauthenticated write routes remaining

**FIXED** done **PARTIAL** incomplete **MISSING** not built **YOU** needs your action **OK** verified working

## 1. Needs you — nothing else can fix these

| Item                                                         | Why it matters                                                                                                                                                                                                                                                                                                        |
|--------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Rotate the VPS root password; switch SSH to keys only</b> | The password was shared in plain text during this work. Highest-priority item on this page.                                                                                                                                                                                                                           |
| <b>Re-enable the Google Drive OAuth client</b>               | Backups run hourly but the off-site copy fails ("OAuth client was disabled"), so every backup sits on the same server as the database. One disk failure loses both.                                                                                                                                                   |
| <b>Re-grant staff KYC access</b>                             | KYC review now needs its own permission. Any existing staff role with "manage users" but not "manage KYC" lost that screen until you edit the role.                                                                                                                                                                   |
| <b>Decide 6 permission mismatches</b>                        | Six admin pages are visible to a role whose API blocks the buttons (announcements, apps, contact inbox, email templates, canned responses, transfer policies). I did <b>not</b> change these: loosening grants staff new access, tightening contradicts the menu. Tell me which way and it is a one-line change each. |
| <b>Google mobile sign-in client ID</b>                       | Now accepts only the web client ID. If the mobile app signs in with an iOS/Android client ID, add it or that login is rejected.                                                                                                                                                                                       |
| <b>Old 2FA enrolments</b>                                    | Admin 2FA set up under the old (broken) method was never readable at login and now reads as disabled — those admins should set it up again.                                                                                                                                                                           |
| <b>Brevo free tier = 300 emails/day</b>                      | Delivery works now that you authorised the server IPs. The daily promotional email is deliberately <b>not</b> scheduled yet — say the word and I will add it, but consider the cap first.                                                                                                                             |
| <b>Stripe card deposits</b>                                  | Fully coded but the <code>stripe</code> package was never installed, so the card tab always says "not configured". Install it or remove the tab.                                                                                                                                                                      |

## 2. What was fixed — by theme

### 2.1 Money

| Bug                                                                                                                                                                                                                                                                                             | Status       |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|
| <b>Crypto-paid plans were free.</b> The payment webhook credited the wallet <i>and</i> activated the plan, so a user paying by crypto got their money back as balance and kept the plan. Subscription payments now activate the plan only, and a partial payment no longer activates it at all. | <b>FIXED</b> |

|                                                                                                                                                                                                                                        |       |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|
| <b>Milestone releases could exceed what the buyer paid.</b> A $\pm 1$ cent tolerance on the milestone sum let the released total drift above the escrow amount. Now must match exactly, with amounts rounded on save.                  | FIXED |
| <b>Sellers paid for promotions that did nothing.</b> Browse ignored every boost flag and the \$2 bump. Ranking now honours premium > featured > pinned > bumped > newest.                                                              | FIXED |
| Partial crypto payments credited an unrounded amount, so the ledger and the balance disagreed by fractions of a cent.                                                                                                                  | FIXED |
| Buying a boost extended from "now" instead of the current expiry, silently destroying paid time.                                                                                                                                       | FIXED |
| Wallet ledger still computes <code>balanceBefore/After</code> with JavaScript floats in ~20 routes while the columns are exact decimals. Balances are correct (the database does the arithmetic); the audit trail can drift over time. | OPEN  |

## 2.2 Security

| Sev.     | Bug                                                                                                                                                                                                                                                           | Status |
|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|
| CRITICAL | <b>Anyone could log in as anyone, including admins.</b> Apple mobile sign-in never verified the token signature — a hand-written token for any email was accepted. Now verified against Apple's keys; a forged token returns 401 on the live server (tested). | FIXED  |
| CRITICAL | Mobile login skipped 2FA for admins, so a leaked admin password was enough.                                                                                                                                                                                   | FIXED  |
| HIGH     | Google sign-in accepted tokens issued for other apps (no audience check).                                                                                                                                                                                     | FIXED  |
| HIGH     | Enrolling admin 2FA permanently locked the account out (written with one cipher, read with another); starting 2FA setup and abandoning it locked users out; 6-digit codes could be guessed without limit.                                                     | FIXED  |
| HIGH     | Bans, password resets and "sign out everywhere" took up to 7 days to apply. Sessions now carry a version and die within 60 seconds.                                                                                                                           | FIXED  |
| HIGH     | Withdrawals required no identity verification. Now gated on phone-level KYC, and high-risk requests are held for review with an admin alert.                                                                                                                  | FIXED  |
| HIGH     | Anyone could crash the realtime server by sending a malformed typing event — it took the whole process down.                                                                                                                                                  | FIXED  |
| MEDIUM   | Uploads trusted the declared file type; a script could be uploaded as an image. Now content is checked against the claimed type, and SVGs are served sandboxed.                                                                                               | FIXED  |
| MEDIUM   | Link moderation used a shared global regex whose position carried between calls, so links slipped through on every other message.                                                                                                                             | FIXED  |
| MEDIUM   | No security headers; staff permissions enforced on only 4 of 46 admin pages; a webhook processed unsigned requests; a hardcoded secret sat in the repo.                                                                                                       | FIXED  |
| MEDIUM   | KYC documents are still readable by anyone holding the link on non-Cloudinary storage, and ~25 routes (uploads, reviews, reports, password change) still have no rate limit. Account lockout is by email only, so anyone can lock any account.                | OPEN   |
| MEDIUM   | No Content-Security-Policy. Needs its own pass because of AdSense, GA4 and the Meta Pixel.                                                                                                                                                                    | OPEN   |

**OK** Verified clean by script across the whole codebase: every data-changing route checks authentication, every admin route carries a permission, no dead links, no broken API calls, no database values crash the page, no type errors. Payment webhooks verify signatures and are replay-safe; passwords use bcrypt; the realtime server authenticates and scopes rooms per user.

## 2.3 Crashes and stuck states

| Bug                                                                                                                                                                                                                                                                          | Status |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|
| <b>Escrows could be frozen forever.</b> Closing a dispute "without action" left the escrow in DISPUTED, which has no way out — funds held permanently. The pre-dispute status is now recorded and restored. No escrow is currently affected (verified: zero disputes exist). | FIXED  |
| <b>Buyers could never accept a counter-offer.</b> Accept/decline were hard-wired to the seller, so a seller's counter sat unanswered until it expired.                                                                                                                       | FIXED  |
| A bad page number ( ?page=abc ) crashed 5 admin pages and 9 admin endpoints; bad filter values and dates crashed the transactions and bank-transfer screens and the CSV export.                                                                                              | FIXED  |
| Two people opening the same escrow at once could double-allocate a manager email; a dispute opened during completion could overwrite a finished payout. Both now guarded.                                                                                                    | FIXED  |
| An already-ruled dispute could still be advanced, overwriting its resolution.                                                                                                                                                                                                | FIXED  |
| Cancelling the "reason" dialog still performed the action — dismissing the box could reject a listing, ban a user or resolve a risk flag.                                                                                                                                    | FIXED  |
| Email or notification failures after a payment surfaced as "purchase failed", prompting retries on an escrow that had already been created.                                                                                                                                  | FIXED  |
| Type errors were ignored at build time — which is how a sweep job referencing a non-existent field shipped and failed silently for days. The build now fails on type errors.                                                                                                 | FIXED  |

## 2.4 Email

| Item                                                                                                                                                                                                                                                         | Status  |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|
| <b>Nothing was being delivered.</b> Brevo rejected every request from the server as an unrecognised IP, and the Gmail fallback is blocked from the VPS. You authorised the IPs; a test send from the server now succeeds and the sending domain is verified. | FIXED   |
| Verification codes reported "sent" even when delivery failed; the resend cooldown never reset; password reset didn't work for Google-only accounts and didn't clear the login lockout; the reset and verify pages dead-ended on failure.                     | FIXED   |
| Wired up and previously missing: new-device sign-in alert, escrow created (buyer), withdrawal approved, offer expired (both sides), KYC submitted, listing submitted, subscription activated and renewal reminder, dispute opened, low balance.              | FIXED   |
| <b>Advance</b> warnings now exist 24h before escrow, dispute-evidence and boost deadlines, and 12h before an offer expires — previously users were only told <i>after</i> the deadline passed.                                                               | FIXED   |
| Promotional email: failed sends were recorded as sent (losing the campaign permanently), unverified addresses were emailed, a button led to a 404, and no promo email had an unsubscribe link. All fixed; the marketing sweep runs daily at 09:15.           | FIXED   |
| All 26 HTML templates had invalid table markup; one showed "Awaiting funding" for an already-funded escrow.                                                                                                                                                  | FIXED   |
| Queued email (if Redis is ever enabled) knew only SMTP and would have silently dropped every message on this Brevo-only setup.                                                                                                                               | FIXED   |
| Per-type email preferences are honoured by all new emails but still ignored by ~35 older send sites. No one-click unsubscribe header.                                                                                                                        | PARTIAL |

## 2.5 What users and staff gained

| Area | Added |
|------|-------|
|------|-------|

|                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Sellers        | Pause/resume without re-review · bulk pause, resume, mark sold, relist, delete and price adjust · a promotions manager with expiry, extend, cancel, history and spend · per-listing analytics (views, uniques, watchlist adds, offers, conversion, 30-day chart, top countries) · sold listings visible in the marketplace with relist.                                                                                                                                                                                                                             |
| Buyers & users | Support tickets with attachments and threads · a dispute centre with timeline and evidence · promo-code entry at checkout and deposit · working mobile navigation (12 of 17 sections were unreachable on a phone) · dark-mode toggle inside the app.                                                                                                                                                                                                                                                                                                                |
| Admin          | Promotions management · promo-code management · a support inbox with assignment, priorities, internal notes and canned replies · a risk case page with factors, flags, devices, login history and force sign-out · working KYC document viewer (it previously showed encrypted text, so approvals were blind) · working dispute resolution (the controls existed but were never connected, so no dispute could release funds) · audit log in the menu · real pagination on bank transfers · role permissions enforced on all 46 pages with a permission-aware menu. |
| Intelligence   | KYC documents are now read by a vision model: name, date of birth, document number, expiry, document type, quality and tamper suspicion feed the admin panel's previously-always-empty widgets. Deliberately no auto-approval and no invented face-match or liveness score. Uploads are cryptographically bound to the uploader; KYC files move to private storage with expiring links.                                                                                                                                                                             |
| Risk           | Device fingerprints are now recorded, so the multi-account rule (the heaviest, previously dead) can fire. Scores recompute on withdrawal, listing creation and disputes, and high-risk withdrawals are held.                                                                                                                                                                                                                                                                                                                                                        |
| SEO            | 41 pages had doubled titles; every page without its own canonical was pointing at the homepage. Fixed, plus per-page descriptions, noindex on private areas, sitemap and structured data. The social share image was a blank 1×1 pixel — replaced with a real one.                                                                                                                                                                                                                                                                                                  |
| Look & feel    | One modern icon set across ~92 files, replacing ~200 lines of emoji-as-icon. Popups no longer stack on the cookie banner; the announcement bar collapses on phones.                                                                                                                                                                                                                                                                                                                                                                                                 |

## 3. What is still missing

### 3.1 Revenue features you are already advertising

| Feature                                     | Status  | Note                                                                                                                                                                                               |
|---------------------------------------------|---------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Advertising system                          | MISSING | No advertiser accounts, banner slots, scheduling, impressions or billing. Nothing exists in the database for it. "Sponsored" today is only seller self-promotion; third-party ads are raw AdSense. |
| Invoices and receipts                       | MISSING | No receipt for a purchase or sale, no annual tax summary, no transaction export for users.                                                                                                         |
| Saved payout methods                        | MISSING | Bank/crypto details are retyped on every withdrawal and stored unencrypted in transaction metadata. No alert when the destination changes.                                                         |
| Loyalty points / affiliate tiers            | MISSING | Referrals are a flat refer-a-friend with no commission tiers or payout history.                                                                                                                    |
| Compare listings · price-drop target alerts | MISSING |                                                                                                                                                                                                    |
| Niche/category filter                       | MISSING | Every seller fills in a niche and nobody can filter by it. A complete full-text search engine also exists in the code and is wired to nothing.                                                     |

### 3.2 Admin gaps

| Missing screen                                                                                                          | Consequence                                                                                                                       |
|-------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|
| Reviews moderation                                                                                                      | An abusive or retaliatory review cannot be removed.                                                                               |
| Wanted listings moderation                                                                                              | User-posted "wanted" ads have no review queue at all.                                                                             |
| Auctions / bids                                                                                                         | No bid viewer, no way to void a fraudulent bid.                                                                                   |
| Organizations · API keys & webhooks · sessions and login attempts · data-export requests · NPS results · push broadcast | Data is collected or configurable in the database with no way to see or act on it. User API keys in particular cannot be revoked. |
| Bulk actions and pagination                                                                                             | No multi-select anywhere in admin; several queues still load a fixed number of rows with no paging.                               |
| Flagged-message review                                                                                                  | Messages caught by moderation are flagged in the database and shown to no one.                                                    |

### 3.3 Platform

| Item                                    | Status    | Note                                                                                                                                                                                     |
|-----------------------------------------|-----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| KYC face match & liveness               | MISSING   | Deliberate. Text extraction is done; matching a selfie to an ID and proving liveness need a real biometric service — a chat model guessing a number here is worse than leaving it empty. |
| Multi-language                          | NOT WIRED | English and Spanish files exist with a few dozen strings, but the language is hardcoded, no component reads translations and there is no switcher.                                       |
| Cookie consent actually gating trackers | PARTIAL   | AdSense, GA4 and the Meta Pixel load regardless of the visitor's choice. The policy pages now describe this accurately, but the banner does not yet enforce it. GDPR exposure.           |
| 2FA backup codes · user passkeys        | MISSING   | Admins have passkeys; users do not. No recovery codes are shown at setup.                                                                                                                |

|                                               |         |                                                                                            |
|-----------------------------------------------|---------|--------------------------------------------------------------------------------------------|
| Duplicate-listing and price-anomaly screening | MISSING | The same account URL can be listed unlimited times. Listing fraud screening is regex-only. |
| Two public profile URLs                       | PARTIAL | Canonical tag now points at one, but both pages still exist and diverge.                   |

## 4. Suggested order from here

1. **Your list in section 1** — the root password above all, then off-site backups.
  2. **Close the remaining security gaps** — private KYC files everywhere, rate limits on the remaining routes, IP-aware lockout, a Content-Security-Policy.
  3. **Finish what is already sold** — invoices/receipts, saved payout methods, the niche filter, and switching browse to the search engine that already exists.
  4. **Advertising system** — the largest missing revenue feature, and a genuine build rather than a fix.
  5. **Admin completeness** — reviews, wanted listings, auctions, API keys, sessions; bulk actions and pagination everywhere.
  6. **Then** — decimal-exact ledger arithmetic, real multi-language, consent-gated trackers, biometric KYC.
- On verification:** everything above was checked in source, and the deployed site was verified by page loads, HTTP status checks, a forged-token probe, a live sweep run and database queries. Nobody has signed in and clicked through the new screens end to end — the local database is not running, and I will not exercise flows against live customer data. Treat the new seller, support and dispute screens as needing a human pass before you rely on them.